MoMo REST API Report

Team 11

Tiffany Lina Turate | Admire Chagaresango | Lydivine Nshuti

1. Introduction to API Security

An API allows different applications to communicate. In this project, the MoMo API lets apps access mobile money transaction records. Without security, anyone could read or delete that data.

We protected all endpoints using Basic Authentication. Every request must include a valid username and password. Invalid credentials return a 401 Unauthorized error.

2. API Endpoint Documentation

Base URL: http://localhost:8000

Auth: Basic Auth — username: admin, password: password

Method	Endpoint	Description	Auth
GET	/transactions	List all transactions	Yes
GET	/transactions/{id}	Get one transaction	Yes
POST	/transactions	Add a transaction	Yes
PUT	/transactions/{id}	Update a transaction	Yes
DELETE	/transactions/{id}	Delete a transaction	Yes

GET /transactions

curl -u admin:password http://localhost:8000/transactions

Response 200: List of all transactions Response 401: {"error": "Unauthorized"}

GET /transactions/{id}

```
curl -u admin:password http://localhost:8000/transactions/1
```

Response 200: Single transaction object Response 404: {"error": "Not found"}

POST /transactions

```
curl -u admin:password -X POST http://localhost:8000/transactions \
  -H "Content-Type: application/json" \
  -d '{"id":"1","amount":5000,"currency":"RWF"}'
```

Response 201: {"message": "Created", "data": {...}}

PUT /transactions/{id}

```
curl -u admin:password -X PUT http://localhost:8000/transactions/1 \
  -H "Content-Type: application/json" \
  -d '{"id":"1","amount":9999,"currency":"RWF"}'
```

Response 200: {"message": "Updated", "data": {...}}

DELETE /transactions/{id}

```
curl -u admin:password -X DELETE http://localhost:8000/transactions/1
```

Response 200: {"message": "Deleted"}

Error Codes

Code	Status	Meaning
200	OK	Request succeeded
201	Created	Transaction added
401	Unauthorized	Wrong or missing credentials
404	Not Found	Transaction ID does not exist

3. DSA Comparison Results

We compared two methods for finding a transaction by ID across 1,562 records. Each method was tested on 25 IDs with 10,000 runs each.

Transaction ID	Linear Search	Dict Lookup	Speedup
1161	68.80	0.13	546x
1508	90.33	0.12	738x
1440	99.01	0.12	812x
703	39.61	0.14	291x
40	2.08	0.14	15x
AVERAGE	**48.30**	**0.14**	**350x**

Dictionary lookup was on average 350x faster than linear search. Linear search scans every record one by one — O(n). Dictionary lookup uses a hash table to jump directly to the record — O(1).

Other structures that could help: Binary Search O(log n), SQLite index for large datasets, Trie for string-based searches.

4. Basic Auth Limitations

Basic Authentication sends the username and password with every request encoded in Base64. It has serious weaknesses:

- Base64 is not encryption — it can be decoded instantly
- Credentials are sent with every request — one intercept gives full access
- No expiry — stolen credentials work forever
- Unsafe without HTTPS — credentials travel as plain text

Stronger Alternatives

JWT (JSON Web Tokens): User logs in once and gets a signed token with an expiry time. All future requests use the token, not the password. Tokens can be revoked.

OAuth 2.0: Industry standard used by Google and GitHub. Users grant specific permissions without sharing their password. Best for apps that need third-party access.

For a real financial API like MoMo, JWT over HTTPS is the minimum recommended standard.